PROJET CAPSTONE

Éthique & Sécurité

EU AI Act et audit d'équité

Classement, obligations et surveillance du modèle de détection de fraude — Système Intelligent de Détection de Fraudes Médicales, d'Optimisation des Remboursements Santé & d'Assistant Agentique

Réalisé par :

ANDRIAMBOLOLONA Riantsoa Cherica
OLIVETTE Jason Brad Mirado
ANDRIAMIHAJA Henintsoa Jerry

Date : Mercredi 21 Octobre 2026

Périmètre	Modèle supervisé de détection de fraude, assistant documentaire (RAG), décision humaine
Référentiel	Règlement (UE) 2024/1689, annexes III, IV et VI ; RGPD ; principe de non-discrimination

1. Synthèse

La plateforme attribue un score de fraude à une facture de santé. Le score ne décide jamais seul : il priorise une file de contrôle, et un gestionnaire décide. Malgré cette supervision humaine, le projet retient par précaution un classement haut risque au sens de l'annexe III du règlement (UE) 2024/1689, par analogie avec les systèmes qui évaluent une situation personnelle et orientent une décision financière.

Le système n'est pas certifié. Les obligations démontrables sont présentes : documentation, journalisation, supervision humaine, explications de la note, tests, audit d'équité, surveillance de la dérive, et désormais un registre des risques formel. Les obligations formelles restent à produire : documentation annexe IV, système de management de la qualité, évaluation de conformité, déclaration UE, marquage CE, enregistrement, plan de surveillance après commercialisation et procédure d'incident grave.

L'audit d'équité montre un rappel global de 87,0 % et des écarts par segment. Les points faibles sont connus :

- CABINET_GENERALISTE : rappel 0,7622 sur 2 518 factures ;
- TRES_ELEVE : rappel 0,7922 sur 870 factures ;
- 30–49 ans : rappel 0,8465 sur 2 638 factures ;
- DOUBLON : rappel 0,2252, qui relève d'une limite des données plutôt que du modèle.

L'audit est un point de départ, pas une preuve d'absence de biais. Il manque des intervalles de confiance, une analyse intersectionnelle, une mesure du taux de faux positifs par segment et une surveillance en production. Le risque d'iniquité est visible, mesuré et encadré, mais pas éliminé.

2. Fiche système

Élément	Description
Nom	Système de détection de fraude à la facturation santé
Finalité	Prioriser les factures à contrôler, aider le gestionnaire à décider
Utilisateurs	Gestionnaires, administrateurs, professionnels de santé, assurés
Données d'entrée	Factures pseudonymisées, actes, montants, dates, prestataire, profil assuré, ordonnances
Sortie	Score de fraude, seuil, version du modèle, contributions d'explication
Décision	Humaine : valider, rejeter, demander une pièce
Modèle	XGBoost supervisé, entraîné sur données synthétiques
Version	v2, seuil 0,2876

Performance	ROC-AUC 0,9500 ; rappel 0,8702 ; précision 0,5969
Rôle	Fournisseur du système de fraude ; l'assureur sera déployeur
Assistant documentaire	gpt-4o-mini via API, sources contractuelles, réponse citée

Le système de fraude est un modèle supervisé entraîné par l'équipe. Ce n'est pas un modèle d'IA à usage général. Le fournisseur du modèle de langage, OpenAI, porte les obligations GPAI ; l'éditeur de la plateforme en est le déployeur pour l'assistant documentaire.

3. Classification AI Act

3.1. Calendrier d'application

Le règlement est entré en vigueur le 1er août 2024. Les obligations applicables aux systèmes haut risque de l'annexe III s'appliquent depuis le 2 août 2026. Les obligations des systèmes de l'annexe I s'appliquent à partir du 2 août 2027. La date du 21 octobre 2026 se situe donc après l'échéance des obligations haut risque de l'annexe III.

Ce calendrier ne dit pas que le système est conforme : il dit que les obligations sont applicables et que les preuves doivent exister.

3.2. Pratiques interdites

Pratique (art. 5)	Présente ?	Justification
Manipulation ou tromperie	Non	Le score et le seuil sont expliqués
Exploitation d'une vulnérabilité	Non	Pas de ciblage de personnes vulnérables
Scoring social	Non	Pas de notation de comportement social
Police prédictive	Non	Pas de données pénales
Biométrie	Non	Aucune image, aucun visage
Extraction non ciblée	Non	L'assistant lit les contrats et le dossier de la personne

3.3. Classement retenu

Question	Réponse
Système listé explicitement à l'annexe III ?	Pas nommément : la détection de fraude n'est ni « tarification » ni « évaluation de solvabilité »
Le score oriente-t-il une décision financière ?	Oui, il priorise un contrôle qui peut retarder ou refuser un remboursement
Classification prudente	Haut risque, annexe III, 5 b, par analogie
Classification alternative défendable ?	Risque limité si le score ne sert qu'à prioriser un contrôle sans effet sur le droit au remboursement
Décision finale	Humaine, tracée, contestable
Rôle de l'éditeur	Fournisseur du système ; assureur déployeur
Rôle d'OpenAI	Fournisseur GPAI ; l'éditeur est déployeur

Le classement haut risque est une lecture de précaution. Il oblige à produire les preuves des articles 9 à 15, 17, 43, 47 à 49, 72 et 73. Si le juriste retient le risque limité, les obligations changent, mais les mesures de transparence, de supervision et de sécurité restent nécessaires.

3.4. Rôle fournisseur / déployeur

L'éditeur de la plateforme est fournisseur du système de fraude : il le conçoit, l'entraîne, le documente et le met à disposition. L'assureur est déployeur : il l'utilise dans son processus de contrôle et doit respecter les obligations de l'article 26.

Si l'éditeur appose sa marque sur un système fourni par un tiers, ou modifie substantiellement un système haut risque, il peut devenir fournisseur de ce système. Cette requalification doit être vérifiée contractuellement.

4. Grille des obligations

Obligation	Art.	Preuve disponible	Statut	Action
Système de gestion des risques	9	Registre des risques, rapports modèle et équité	Partiel	Revue périodique
Gouvernance des données	10	84 593 factures, contrôle qualité, SHA-256	Partiel	Fiche de données annexe IV
Documentation technique	11	Ce dossier, README, ADR, model card	Partiel	Trame annexe IV
Journalisation	12	Audit décisions, connexion, seuil, modèle	Partiel	Couvrir actions restantes
Transparence	13	Contributions d'explication, seuil, version	Partiel	Expliquer le score à l'assuré
Supervision humaine	14	Décision humaine, commentaire, audit	Démontré	Procédure d'escalade
Exactitude, robustesse, cybersécurité	15	ROC-AUC, rappel, 784 tests, RBAC	Partiel	Tests adverses, TLS
Système de management de la qualité	17	CI, revue, tests, versionnement	Partiel	QMS formel
Obligations du déployeur	26	Supervision, logs, information	Partiel	Guide déployeur
Évaluation de conformité	43	Auto-évaluation interne possible	Écart	Réaliser
Déclaration UE	47	—	Écart	Rédiger
Marquage CE	48	—	Écart	Apposer
Enregistrement	49	—	Écart	Enregistrer base UE
Transparence IA	50	Mention IA affichée sur l'assistant	Partiel	Étendre à l'écran de notation
Surveillance après commercialisation	72	Worker de dérive, Prometheus, Grafana	Partiel	Plan de surveillance écrit

Incidents graves	73	Logs, audit, sauvegardes	Écart	Procédure de notification
Évaluation des droits fondamentaux	27	AIPD RGPD	À évaluer	FRIA si requise
GPAI	53	Modèle OpenAI	Déployeur	Vérifier DPA

4.1. Article 9 — Gestion des risques

Le règlement exige un processus continu d'identification, d'évaluation et de réduction des risques. Ce registre existe désormais : docs/cadrage/registre_risques.md recense 11 risques, chacun rattaché à un article, avec sa mesure de maîtrise, son risque résiduel et la preuve dans le dépôt. Les rapports de modèle, l'audit d'équité, les tests et la surveillance de dérive fournissent la matière de ce registre.

Ce qui manque : la revue périodique du registre et la mise à jour systématique après chaque évolution du système.

4.2. Article 10 — Gouvernance des données

Le jeu d'entraînement contient 84 593 factures synthétiques, sans doublon exact, avec une empreinte SHA-256. Les données sont adaptées à la finalité, mais il manque une fiche de données décrivant la provenance, les transformations, les limites, les biais connus et les variables interdites. Le cas DOUBLON montre que l'étiquette peut ne pas correspondre à un signal observable : c'est une limite de données à documenter.

4.3. Article 11 — Documentation technique

La documentation technique de l'annexe IV doit décrire le système, sa finalité, ses composants, ses données, ses performances, ses limites, sa supervision, sa cybersécurité et sa maintenance. Les présents livrables en fournissent une base, mais il faut une trame unique, versionnée et signée.

4.4. Article 12 — Journalisation

Les décisions, les connexions, les changements de seuil, les changements de modèle, la gestion des comptes, les canaux et les secrets sont tracés. Les journaux doivent permettre de reconstituer une décision : qui, quand, sur quelle facture, avec quel score, quel seuil, quelle version et quel commentaire. La journalisation des actions d'administration doit être complétée sur les rares cas restants.

4.5. Article 13 — Transparence

Le gestionnaire voit le score, le seuil, la version et les contributions d'explication. La personne assurée doit savoir qu'un système d'IA contribue au contrôle et pouvoir contester.

Deux choses ont changé. D'abord, la mention « Réponse générée par un assistant IA — vérifiez les sources citées » est désormais affichée sur l'écran de l'assistant. Ensuite, l'API ne renvoie plus de contributions « à zéro » comme s'il s'agissait d'une explication : quand

l'explication n'est pas disponible, elle le dit (shap_available = false), et le journal serveur trace l'incident. L'interface, elle, ne distingue pas encore les deux cas : elle affiche « aucune contribution enregistrée ». C'est un petit écart à traiter.

Reste l'explication vulgarisée du score pour la personne assurée.

4.6. Article 14 — Supervision humaine

La supervision est réelle :

1. le modèle produit un score et un rapport d'explication ;
2. la facture arrive dans la file du gestionnaire ;
3. le gestionnaire lit les contributions et décide ;
4. la décision est écrite avec acteur, horodatage et commentaire ;
5. la facture sort de la file.

Le score ne rejette jamais automatiquement une facture. La procédure d'escalade, le droit de contestation et la formation des gestionnaires restent à formaliser.

4.7. Article 15 — Exactitude, robustesse, cybersécurité

Les métriques du modèle sont documentées. Les tests couvrent les attaques de l'assistant, le SQL, le RBAC et les garde-fous. Une comparaison à trois bases de décision (reports/baselines_v2.md) a été produite sur le même découpage temporel et les mêmes variables : les règles déterministes seules atteignent un rappel de 0,6595, la régression logistique 0,8747, le modèle à arbres 0,8838, et l'union « règles + modèle » 0,9260. Le modèle retenu est celui qui minimise le coût métier. Cette comparaison porte sur un modèle ré-entraîné pour l'occasion, pas sur l'artefact de production.

Il manque des tests de robustesse sur des données perturbées, des tests adversariaux sur le modèle tabulaire, un test d'intrusion externe et une preuve de TLS en production.

4.8. Article 17 — Système de management de la qualité

La CI, les revues, les tests, le versionnement et les ADR sont des briques de QMS. Il manque une politique qualité formelle, des procédures documentées, des audits internes et un propriétaire du QMS.

4.9. Article 26 — Obligations du déployeur

L'assureur doit utiliser le système conformément aux instructions, assurer la supervision humaine, conserver les logs, informer les personnes et signaler les incidents. Le guide d'exploitation et le guide utilisateur doivent fournir ces éléments : c'est le rôle du document 05.

4.10. Articles 43, 47, 48, 49 — Mise sur le marché

L'évaluation de conformité, la déclaration UE, le marquage CE et l'enregistrement ne sont pas réalisés. Pour un système haut risque de l'annexe III, l'évaluation peut être interne (annexe VI)

lorsque les normes harmonisées sont appliquées. Un organisme notifié peut être requis dans certains cas. Ces trois obligations doivent être traitées avant toute exploitation réelle : tant qu'elles ne le sont pas, le système ne peut pas être présenté comme conforme à l'AI Act. La décision doit être prise avec le juriste.

4.11. Article 50 — Transparence de l'IA

L'utilisateur doit savoir qu'il interagit avec un système d'IA. L'interface affiche désormais une mention claire, sans jargon, et explique les limites de la réponse. C'est une obligation de transparence, pas une simple mention légale. L'écran de notation de fraude n'affiche pas encore de mention équivalente.

4.12. Articles 72 et 73 — Surveillance et incidents

Le worker de dérive, les règles d'alerte Prometheus et les deux vues Grafana versionnées fournissent des signaux réels. Il manque un plan de surveillance après commercialisation écrit, des seuils d'escalade, un responsable désigné, un registre d'incidents et une procédure de notification à l'autorité et au fournisseur. Le PSI est calculé et persisté mais pas encore exposé en métrique : l'alerte Prometheus se base sur un indicateur de substitution (part des scores au-dessus de 0,3).

4.13. Article 27 — Évaluation des droits fondamentaux

Une FRIA peut être requise pour certains déployeurs. L'assureur doit évaluer si son usage entre dans le champ. À défaut, l'AIPD RGPD couvre une partie des risques, mais pas toute l'analyse des droits fondamentaux.

4.14. Article 53 — GPAI

OpenAI fournit le modèle de langage. L'éditeur de la plateforme en est le déployeur : il doit documenter le modèle et sa version, vérifier les conditions, minimiser les données, prévoir un repli et surveiller le coût. Il ne devient pas fournisseur GPAI du seul fait qu'il utilise l'API.

5. Audit d'équité

5.1. Méthode

L'audit porte sur le jeu de test du modèle v2 : 10 086 factures, 878 fraudes, taux de fraude 8,7 %. Le rappel et la précision sont calculés par segment. Le seuil a été choisi sur le jeu de validation, pas sur le test, pour éviter une fuite de données.

Deux limites méthodologiques doivent être lues avant les tableaux :

- les segments de petite taille sont fragiles : un écart sur 80 factures n'a pas la même portée qu'un écart sur 3 000 ;
- les agrégats publiés ne permettent pas de calculer des intervalles de confiance par segment, faute du nombre de positifs par segment.

5.2. Performance globale

Indicateur	Valeur
ROC-AUC	0,9500
PR-AUC	0,8913
Rappel	0,8702
Précision	0,5969
F1	0,7081
Spécificité	0,9440
Seuil	0,2876

Le rappel global est sous l'objectif de 90 %. Baisser le seuil à 0,20 porterait le rappel à environ 89 %, au prix de près de 1 000 faux positifs supplémentaires. Le seuil est donc un arbitrage métier, pas une vérité statistique.

5.3. Par tranche d'âge

Segment	n	Rappel	Précision
0–17	3 378	0,8902	0,6651
18–29	927	0,8929	0,5639
30–49	2 638	0,8465	0,5778
50–64	3 009	0,8559	0,5460
65+	134	0,8889	0,5333

Le segment 30–49 ans a le rappel le plus faible sur un volume significatif. L'écart est modéré (environ 2,4 points sous le global) et doit être surveillé, pas conclu. Le segment 65+ a un rappel correct mais seulement 134 factures : le résultat n'est pas robuste.

5.4. Par niveau de tarif

Segment	n	Rappel	Précision
ÉLEVÉ	2 623	0,9214	0,4741
RAISONNABLE	6 593	0,8489	0,6914
TRES_ELEVE	870	0,7922	0,8841

TRES_ELEVE a le rappel le plus faible et la précision la plus élevée : le modèle est prudent, il alerte peu, mais juste. Ce n'est pas nécessairement un biais ; cela peut refléter des montants plus élevés et un contrôle plus coûteux. L'analyse des contributions par segment est nécessaire pour trancher.

5.5. Par type de prestataire

Segment	n	Rappel	Précision
CABINET_DENTAIRE	202	0,9722	0,6481
CABINET_GENERALISTE	2 518	0,7622	0,4941

CABINET_SPECIALISTE	535	0,9667	0,2358
CENTRE_IMAGERIE	205	0,8571	0,9474
CLINIQUE	1 922	0,8586	0,3899
LABORATOIRE	667	0,9216	1,0000
OPTICIEN	80	0,8889	1,0000
PHARMACIE	3 910	0,9011	0,9850

CABINET_GENERALISTE est l'écart le plus important sur un segment suffisamment peuplé : 0,7622 de rappel sur 2 518 factures, soit environ 11 points sous le global. L'explication probable est une activité plus hétérogène, avec des actes courants et des volumes élevés qui diluent le signal. Elle reste à confirmer par une analyse des contributions et des types de fraude.

5.6. Par formule

Segment	n	Rappel	Précision
CONFORT	2 125	0,8556	0,5498
ESSENTIEL	5 580	0,8733	0,5910
PREMIUM	2 381	0,8764	0,6753

Les écarts entre formules sont faibles. La formule n'apparaît pas comme un facteur majeur d'iniquité sur ce jeu.

5.7. Par type de fraude

Type	n	Rappel
ACTE_FICTIF	53	1,0000
DOUBLON	111	0,2252
FRACTIONNEMENT	37	0,7838
INCOHERENCE_PROFIL	33	1,0000
LIGNES_NON_PRESCRITES	87	1,0000
ORDONNANCE_EXPIREE	76	1,0000
PRESTATAIRE_RADIE	55	1,0000
QUANTITE_EXCESSIVE	59	0,9153
SUBSTITUTION_PRODUIT	43	1,0000
SURCONSOMMATION	37	1,0000
SURFACTURATION	165	1,0000
UPCODING	82	0,8171

5.8. Le cas DOUBLON

DOUBLON a un rappel de 0,2252. Ce n'est pas seulement une faiblesse du modèle : sur 909 factures étiquetées DOUBLON, seules 12 ont une signature répétée et 14 partagent leur

numero_facture avec une autre facture. En pratique, environ 98 % des cas n'ont aucune duplication observable.

Réentraîner le modèle ne résoudra pas ce problème. La bonne réponse est une règle déterministe sur numero_facture à la réception, avant le scoring. Les règles d'invalidité existent déjà dans predicare_seed.qualite_donnees ; la règle anti-doublon de soumission reste à brancher.

5.9. Lecture d'ensemble

L'audit montre trois choses :

- le modèle est globalement performant, avec un rappel élevé et une précision modérée ;
- certains segments ont des écarts réels, notamment les cabinets généralistes et les tarifs très élevés ;
- une partie des écarts vient des données, pas du modèle, comme le montre DOUBLON.

Il ne montre pas :

- si les écarts sont statistiquement significatifs, faute d'intervalles de confiance ;
- si les écarts se cumulent pour une même personne (analyse intersectionnelle) ;
- si le taux de faux positifs est plus élevé pour un groupe, faute du nombre de négatifs par segment ;
- si la décision humaine corrige ou aggrave l'écart.

Ces limites doivent être explicites dans toute présentation. Un audit d'équité n'est pas un certificat d'absence de biais.

5.10. Mesures

Mesure	Effet attendu	État
Décision humaine obligatoire	Empêche un refus automatique	En place
Audit d'équité versionné	Rend les écarts visibles	En place
Registre des risques versionné	Trace les risques et leur résiduel	En place
Règle déterministe numero_facture	Couvre DOUBLON	À brancher
Surveillance par segment	Détecte une dérive d'équité	À ajouter
Seuil par segment	Réduit l'écart, mais risque juridique	Non recommandé sans avis
Données supplémentaires généralistes	Améliore le rappel	À planifier
Explication au gestionnaire	Permet de contester le score	En place
Formation des gestionnaires	Réduit le risque de décision mécanique	À formaliser

5.11. Seuils de surveillance proposés

Indicateur	Seuil d'alerte	Action
Écart de rappel	> 10 points sur un segment de plus de 500 factures	Revue data science
Baisse de rappel global	> 5 points sur un mois	Revue modèle
Baisse de précision	> 10 points	Revue seuil
Dérive PSI	> 0,2	Alerte
Volume de plaintes	> 5 par mois	Revue humaine
Écart de faux positifs	> 10 points	Analyse et mitigation

Ces seuils sont des propositions. Ils doivent être validés par le métier et le juriste, et intégrés au plan de surveillance après commercialisation.

6. Risques et plan d'action

Risque	Gravité	Mesure	Responsable	Échéance
Classement AI Act erroné	Élevée	Avis juridique	Juriste	Avant production
Documentation annexe IV absente	Élevée	Trame et revue	Direction	Avant production
QMS absent	Moyenne	Politique et procédures	Direction	Avant production
Biais non détecté	Élevée	Audit, surveillance, mitigation	Data science	Continu
Décision humaine mécanique	Moyenne	Formation, audit	Métier	Lancement
Incident non notifié	Élevée	Runbook 72 h	RSSI	Avant production
Évaluation de conformité absente	Élevée	Réaliser	Direction	Avant mise sur le marché
Marquage CE absent	Élevée	Réaliser	Direction	Avant mise sur le marché
RLS PostgreSQL absente	Moyenne	Isolation API ; activer RLS si besoin	Exploitation	Avant production
PSI non exposé en métrique	Moyenne	Publier jauge de dérive et alerte	Exploitation	Avant production

La gradation des risques résiduels (faible, moyen, élevé) et la liste des écarts assumés sont tenues dans le registre : docs/cadrage/registre_risques.md.

7. Conclusion

La plateforme est conforme par conception sur les points démontrables : décision humaine, explications, journalisation, minimisation, tests, audit d'équité, surveillance de dérive, registre des risques. Elle n'est pas certifiée : l'évaluation de conformité, le QMS, la déclaration UE, le marquage CE, l'enregistrement et le plan de surveillance restent à produire.

Le classement haut risque est une lecture prudente, pas une évidence. Si le juriste retient le risque limité, les obligations formelles diminuent, mais les mesures de transparence, de supervision et de sécurité restent nécessaires. Dans les deux cas, la priorité est la même : rendre les preuves disponibles, compréhensibles et vérifiables.